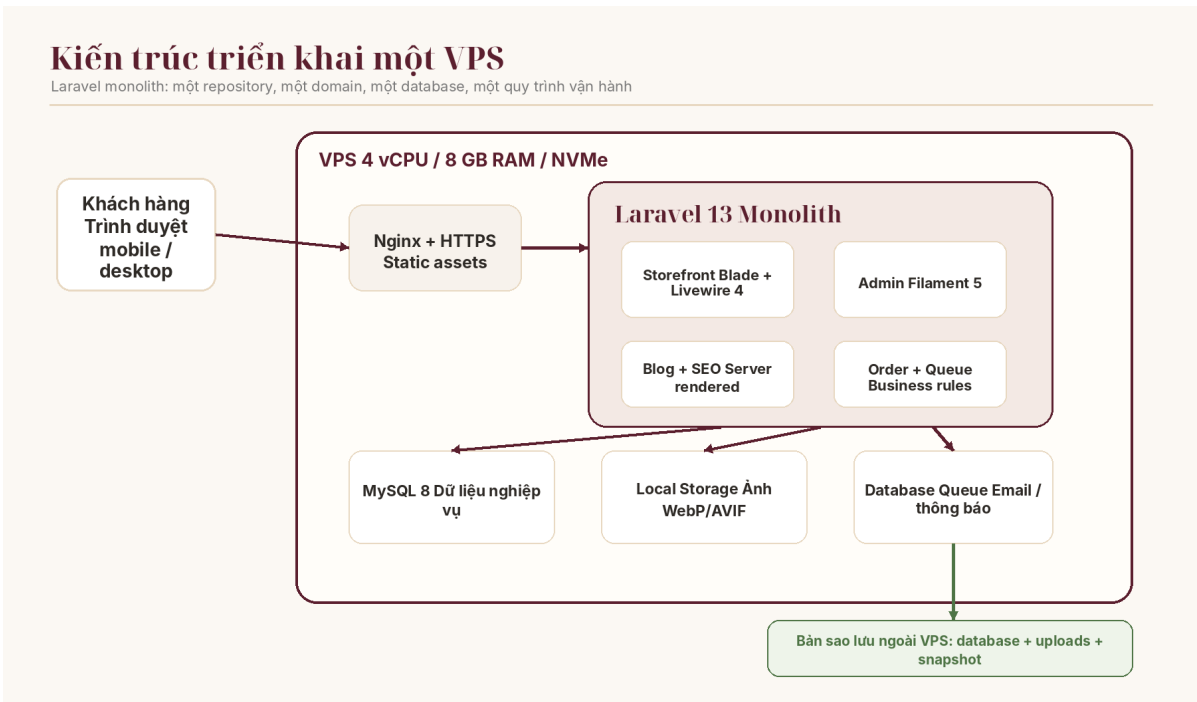


Thiết kế kỹ thuật Laravel trên một VPS

Kiến trúc ứng dụng, module, bảo mật, hiệu năng và quy ước code

Mã tài liệu	OUT-TECH-001
Phiên bản	1.0
Ngày phát hành	28/07/2026
Trạng thái	BASELINE ĐÃ KHÓA



QUYẾT ĐỊNH NỀN TẢNG Laravel 13 monolith trên một VPS; Blade + Livewire 4 cho storefront; Filament 5 cho admin; MySQL; không tách Cloudflare Pages/Workers trong phiên bản này.

Mục lục nội dung

- 01. Mục tiêu kiến trúc
- 02. Stack phiên bản
- 03. Kiến trúc runtime
- 04. Cấu trúc ứng dụng
- 05. Module boundaries
- 06. Request lifecycle
- 07. Authentication và authorization
- 08. Session cache queue
- 09. Storage và media
- 10. Bảo mật
- 11. Hiệu năng
- 12. Logging monitoring
- 13. Quy ước phát triển
- 14. Cấu hình môi trường
- 15. Rủi ro kỹ thuật
- 16. Nguồn tham chiếu

CÁCH SỬ DỤNG Đọc tài liệu Tổng quan trước, sau đó triển khai theo thứ tự: phạm vi sản phẩm → UI/UX → kiến trúc → dữ liệu & nghiệp vụ → SEO → vận hành & nghiệm thu.

1. Mục tiêu kiến trúc

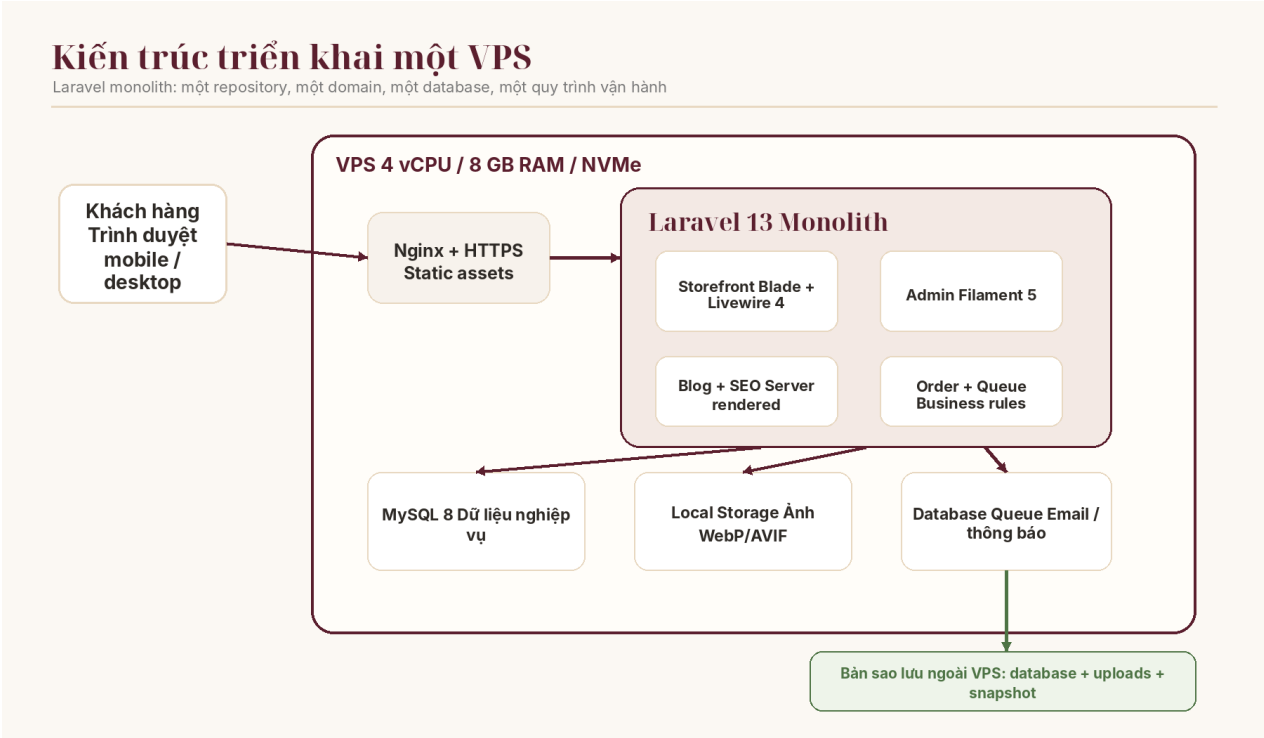
- Một repository, một Laravel application, một database và một domain.
- Không cần Node runtime trong production; Node chỉ dùng build CSS/JS.
- Nghiệp vụ đơn hàng được cô lập trong service/action, không viết rài rác trong controller/Livewire/Filament resource.
- Mọi thay đổi dữ liệu quan trọng dùng transaction và audit trail.
- Có thể nâng VPS theo chiều dọc trước khi nghĩ đến tách dịch vụ.

MỨC TÀI THIẾT KẾ Tối đa 1.000 đơn/ngày; thiết kế load test cao hơn trung bình thực tế để có dư địa cho chiến dịch quảng cáo.

2. Stack phiên bản

Lớp	Công nghệ baseline	Ghi chú
OS	Ubuntu 24.04 LTS	Ưu tiên ổn định và package hệ thống mature.
Web server	Nginx	TLS, static assets, gzip/brotli nếu có module, reverse to PHP-FPM.
Runtime	PHP 8.3 + PHP-FPM	Đáp ứng Laravel 13; OPcache bật.
Framework	Laravel 13	Monolith, server-rendered, built-in queue/scheduler/cache.
UI public	Blade + Livewire 4 + Alpine.js	Không SPA; tương tác nơi cần.
CSS	Tailwind CSS 4	Build-time; tokens theo OUT-UX-001.
Admin	Filament 5	CRUD, forms, tables, widgets.
Database	MySQL 8	InnoDB, utf8mb4, timezone UTC.
Queue	Database queue	Một worker; failed_jobs; retry có giới hạn.
Session	Database	Đăng nhập admin và cart/session ổn định qua deploy.
Cache	File	Đơn giản cho một máy; có thể đổi Redis sau.
Storage	Local public disk	Ảnh web + backup offsite.
Build	Composer 2, Node LTS, Vite	Build trong deploy hoặc CI; production không chạy Vite dev server.

3. Kiến trúc runtime



Kiến trúc runtime một VPS.

Nginx phục vụ file tĩnh trực tiếp và chuyển PHP request vào PHP-FPM. Laravel render storefront, xử lý Livewire request, Filament admin, blog, checkout và business logic. MySQL, queue database và storage đều nằm trên VPS; backup phải nằm ngoài VPS.

4. Cấu trúc ứng dụng

```
app/
├── Actions/
│   ├── Orders/CreateOrder.php
│   ├── Orders/TransitionOrderStatus.php
│   └── Products/AdjustInventory.php
├── Data/
│   └── # DTO/value objects khi cần
├── Enums/
│   └── # OrderStatus, PaymentStatus, ProductStatus
├── Filament/
│   ├── Resources/
│   ├── Pages/
│   └── Widgets/
├── Http/
│   ├── Controllers/
│   ├── Middleware/
│   └── Requests/
├── Livewire/
│   ├── Cart/
│   ├── Checkout/
│   └── Product/
├── Models/
├── Policies/
├── Services/
│   ├── PricingService.php
│   ├── ShippingFeeService.php
│   └── SeoService.php
├── Support/
│   ├── Money.php
│   ├── PhoneNormalizer.php
│   └── SlugRedirector.php
├── resources/views/
│   ├── components/
│   ├── layouts/
│   ├── livewire/
│   ├── pages/
│   └── seo/
├── routes/
│   ├── web.php
│   ├── console.php
│   └── admin.php (nếu tách route group)
```

QUY TẮC DEPENDENCY Controller, Livewire component và Filament action gọi Action/Service. Không để Model event bí mật thực hiện nghiệp vụ lớn như trừ tồn hoặc gửi thông báo.

5. Module boundaries

Module	Trách nhiệm	Không được làm
Catalog	Danh mục, sản phẩm, biến thể, ảnh, tồn hiển thị.	Không tạo đơn hoặc tính phí giao.
Cart	Session cart, normalize quantity, remove/update.	Không tin giá lưu trong session.
Checkout	Validation input, gọi Pricing/Shipping/CreateOrder.	Không ghi trực tiếp từng bảng ngoài transaction action.
Orders	Create, transition, cancel, restore inventory, history.	Không cho UI tự set status.
Blog	Post CRUD, preview, publish, redirect slug.	Không render HTML chưa sanitize.

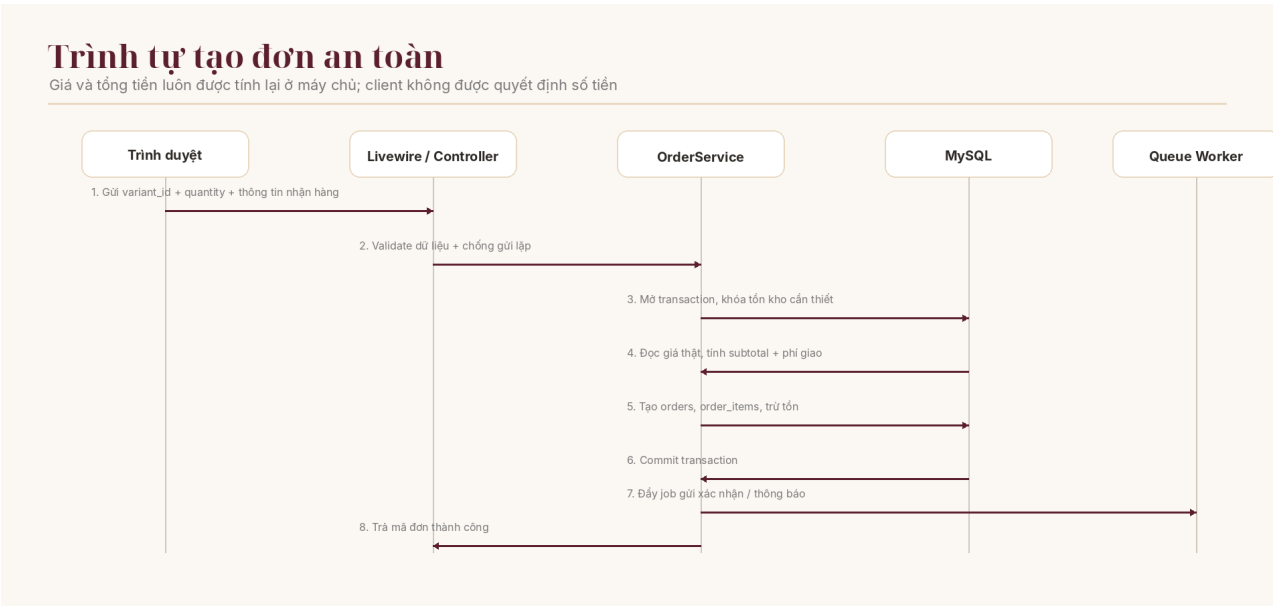
Module	Trách nhiệm	Không được làm
SEO	Meta, canonical, schema, sitemap, robots.	Không hard-code sản phẩm/giá.
Admin	UI vận hành và authorization.	Không chứa business rules chỉ tồn tại trong Filament.

6. Request lifecycle

6.1 Public page

HTTP request
→ Nginx
→ Laravel route/controller or Livewire
→ Query Eloquent/repository
→ ViewModel / SEO data
→ Blade render
→ HTML response
→ Browser hydration only for Livewire islands

6.2 Checkout



Trình tự checkout bảo đảm server-side pricing và transaction.

7. Authentication và authorization

- Không có đăng ký admin public.
- Tạo owner bằng seeder/Artisan command trong quá trình bàn giao.
- Admin route group có auth, verified nếu dùng email, rate limit và session regeneration.
- Phiên bản 1 chỉ có role owner; vẫn dùng Policy/Gate cho resource quan trọng để dễ mở rộng.
- Password tối thiểu 12 ký tự; khuyến nghị password manager; 2FA có thể bật nếu starter/admin hỗ trợ ổn định.
- Logout/timeout không xóa cart guest; admin session tách guard/cookie nếu cần.

8. Session, cache và queue

Hạng mục	Quy định / quyết định
SESSION_DRIVER	database; secure, http_only, same_site=lax; HTTPS bắt buộc.
CACHE_STORE	file; chỉ cache data không nhạy cảm và fragment có invalidation rõ.
QUEUE_CONNECTION	database; one worker, tries=3, backoff 30/120/300 giây.
Failed jobs	Theo dõi trong admin hoặc command; cảnh báo khi >0 job mới.
Cart	Lưu session; mỗi line chỉ giữ variant_id và quantity, không giữ giá làm nguồn sự thật.
Scheduler	Chạy mỗi phút: queue cleanup, sitemap refresh nếu cần, backup trigger, log housekeeping.

9. Storage và media

Dùng Laravel public disk tại storage/app/public và symlink public/storage. File gốc không phục vụ trực tiếp; khi upload tạo derivative phù hợp rồi lưu path trong database.

Variant ảnh	Kích thước gợi ý	Mục đích	Ngân sách dung lượng
thumb	320×320	Admin, cart	≤40 KB
card	640×640	Product grid	≤90 KB
product	1200×1200	Product gallery	≤180 KB
hero	1600×900	Homepage hero	≤250 KB
og	1200×630	Open Graph	≤200 KB

- Whitelist MIME thực, kiểm tra kích thước và decode ảnh; không tin extension.
- Tên file dùng UUID/hash, không dùng nguyên tên upload.
- Xóa file chỉ khi không còn reference; sản phẩm soft delete không tự xóa ảnh ngay.
- Nginx đặt cache-control dài cho file có tên immutable/hash.

10. Bảo mật

Rủi ro	Control bắt buộc
CSRF	Laravel CSRF token cho form/Livewire; không tắt middleware.
XSS	Escape mặc định; sanitize rich text; không render {!! !!} với input thô.
SQL injection	Eloquent/query builder + binding; không nối string SQL từ input.

Rủi ro	Control bắt buộc
Brute force admin	Rate limit login, strong password, 2FA nếu dùng, log failed login.
Order spam	Rate limit checkout theo IP/session/phone; honeypot hoặc CAPTCHA nhẹ khi có dấu hiệu.
Upload độc hại	MIME whitelist, size limit, re-encode ảnh, cấm SVG upload public nếu không sanitize.
Data leak	APP_DEBUG=false; redact phone/address khỏi log; no directory listing.
Privilege bypass	Policy/Gate ở server; không chỉ ẩn nút UI.
Mass assignment	\$fillable/\$guarded rõ; Form Request whitelist.
Unsafe transition	Order status chỉ qua TransitionOrderStatus action.

11. Hiệu năng

- Chạy php artisan optimize trong deploy; route/config/view/event cache theo Laravel.
- OPcache bật; realpath cache hợp lý; production không bật Xdebug.
- Index các cột slug, status, order_number, phone_normalized, created_at và foreign key.
- Eager-load quan hệ trên product/order list; chống N+1 bằng test/query log.
- Không resize ảnh trong request đọc; xử lý lúc upload hoặc queue.
- Pagination admin; dashboard query theo index và range ngày.
- Cache cấu hình cửa hàng, menu/danh mục; invalidate khi admin sửa.
- Không cache cart/checkout/order lookup response.

12. Logging và monitoring

Hạng mục	Thiết kế
Application log	Daily channel, retention 14–30 ngày, production level warning/error.
Audit log	Giá, tồn, trạng thái đơn, publish/slug blog.
Health	/up kiểm tra app boot; custom check database và disk threshold.
Metrics tối thiểu	CPU, RAM, disk, load average, MySQL connections, queue failed, HTTP 5xx.
Correlation	Request ID/order number trong log liên quan checkout.
Alert	Website down, disk >80%, backup stale, failed jobs, SSL sắp hết hạn.

13. Quy ước phát triển

- PHP strict types ở service/action mới; Pint/formatter và static analysis ở mức phù hợp.

- Tên class/DB bằng tiếng Anh; UI/content tiếng Việt.
- Money dùng integer VND; timezone lưu UTC, hiển thị Asia/Ho_Chi_Minh.
- Enums cho trạng thái; không rải magic string.
- Migrations chỉ tiến; không sửa migration đã chạy production.
- Test business rules quan trọng trước UI test.
- Không cài plugin Filament/community nếu chức năng có thể làm đơn giản bằng core.

14. Cấu hình môi trường

```
APP_NAME="O Ut Dac San Hue"
APP_ENV=production
APP_DEBUG=false
APP_URL=https://example.com
APP_TIMEZONE=Asia/Ho_Chi_Minh

DB_CONNECTION=mysql
DB_HOST=127.0.0.1
DB_PORT=3306
DB_DATABASE=ouut
DB_USERNAME=ouut_app
DB_PASSWORD=***

SESSION_DRIVER=database
CACHE_STORE=file
QUEUE_CONNECTION=database
FILESYSTEM_DISK=public
LOG_CHANNEL=daily
LOG_LEVEL=warning

MAIL_MAILER=smtp
MAIL_FROM_ADDRESS=...
MAIL_FROM_NAME="O Ut dac san Hue"
```

BÍ MẬT Không commit .env, database dump, private key hoặc ảnh giấy tờ vào repository. .env.example chỉ chứa tên biến và giá trị giả.

15. Rủi ro kỹ thuật

Rủi ro	Mức	Giảm thiểu
Một VPS là single point of failure	Trung bình	Backup ngoài VPS, snapshot, runbook restore, uptime monitor.
Disk đầy do ảnh/log/backup local	Cao	Quota, logrotate, backup không lưu dài trên máy, cảnh báo 70/80%.
Queue worker chết	Trung bình	Supervisor/systemd auto-restart, monitor failed_jobs.
Plugin admin không tương thích khi nâng cấp	Trung bình	Giảm plugin, lock version, test staging trước composer update.
Checkout race condition tồn kho	Cao	Atomic update/row lock trong transaction; concurrency test.
Nội dung admin gây XSS	Cao	Sanitize HTML, allowlist editor nodes/attributes.

Nguồn tham chiếu kỹ thuật chính thức

Các nguồn dưới đây được dùng để khóa phiên bản nền tảng và quy trình triển khai. Tài liệu dự án này là đặc tả thi công; khi nâng phiên bản lớn phải đánh giá lại tương thích trước khi cập nhật.

- **Laravel 13 - Release Notes:** <https://laravel.com/docs/13.x/releases>
- **Laravel 13 - Deployment:** <https://laravel.com/docs/13.x/deployment>
- **Laravel 13 - Starter Kits:** <https://laravel.com/docs/13.x/starter-kits>
- **Laravel Livewire 4 - Quickstart:** <https://livewire.laravel.com/docs/4.x/quickstart>
- **Filament 5 - Overview:** <https://filamentphp.com/docs/5.x/introduction/overview>
- **Filament 5 - Version Support Policy:** <https://filamentphp.com/docs/5.x/introduction/version-support-policy>
- **Laravel 13 - Database:** <https://laravel.com/docs/13.x/database>
- **Laravel 13 - Queues:** <https://laravel.com/docs/13.x/queues>
- **Laravel 13 - File Storage:** <https://laravel.com/docs/13.x/filesystem>
- **Laravel 13 - Cache:** <https://laravel.com/docs/13.x/cache>